Section 1 — Incident Header

Incident ID: INC-20260414-003
Date: 14 April 2026
Time Opened (IST): 11:26
Severity: Critical
Client: FinSecure Bank
Industry: BFSI (Banking, Financial Services, and Insurance)
L1 Analyst: Arjun Mehta
L2 Analyst: Rohan Desai
L3 Analyst: Nisha Kapoor
Current Status: Under Investigation — Escalated to L2
Sentinel Incident Number: 48217

Section 2 — Client & Environment Context

FinSecure Bank is a mid-sized private banking institution headquartered in Mumbai, serving over 1.2 million customers across retail and corporate segments. The organization operates under strict regulatory oversight, including compliance with RBI IT Framework guidelines, PCI-DSS 4.0 for payment systems, and ISO 27001 certification. Their infrastructure is designed with a strong emphasis on hybrid identity and secure transaction processing, but like most financial institutions, their attack surface remains broad due to the combination of legacy systems and modern cloud integrations.

The bank maintains approximately 950 Windows 10/11 endpoints across its headquarters and three regional branches, along with around 80 Windows Server 2022 systems hosting core services. Two on-premises domain controllers handle authentication locally, synchronized with Azure AD using Azure AD Connect to support cloud-based services and remote access. All employees authenticate through Azure AD, with Conditional Access policies enforcing MFA across the board. Privileged accounts are managed through Privileged Identity Management (PIM), but several service accounts and administrative workflows still rely on traditional authentication mechanisms, particularly within the internal network.

From a security tooling perspective, FinSecure operates a fully integrated Microsoft security stack — Microsoft Sentinel acts as the central SIEM, ingesting logs from Defender for Endpoint, Defender for Identity, Defender for Office 365, Azure Activity Logs, and on-premises event sources. Defender for Identity monitors domain controller traffic for suspicious authentication patterns, making it particularly critical in detecting lateral movement within the network.

The bank's most sensitive assets include its Core Banking System (CBS), a customer PII database hosted in Azure SQL, and internal financial reporting systems used by the finance department. Any compromise of domain credentials — especially those with administrative privileges — poses a direct risk to these systems. Given the interconnected nature of the environment, lateral movement within the internal network is considered a high-risk event, often signaling a deeper compromise that may already be in progress.

For this specific incident, there is no scheduled maintenance or known internal activity that would justify abnormal authentication patterns across multiple servers. This absence of expected noise increases the likelihood that any anomalous behavior detected is malicious in nature rather than operational.

Section 3 — Attack Narrative

The attacker had already achieved their first foothold hours before the lateral movement began. The initial access point was not sophisticated — a single workstation belonging to a mid-level employee in the operations team. What mattered was not the machine itself, but what it could reach.

They began by establishing persistence quietly, ensuring that even if the initial access vector was closed, they would not lose their position. With the endpoint under control, the attacker shifted focus to credential harvesting. Memory was the target. Specifically, the Local Security Authority Subsystem Service — LSASS. Using a credential dumping tool designed to operate with minimal footprint, they extracted cached authentication material directly from system memory.

Among the extracted data was a usable NTLM hash tied to a domain user account. It was not a privileged account — but it did not need to be. In a flat or partially segmented network, even a standard user credential can open doors if used correctly.

The attacker did not attempt to crack the hash. There was no need. Instead, they leveraged it directly using a pass-the-hash technique. This allowed them to authenticate to other systems without ever knowing the actual password. The goal was movement — not identity theft.

They selected four internal servers as targets. Not randomly — these were systems that typically accepted authentication requests and were known to host shared services. File servers, application hosts, and one internal reporting server. The attacker initiated NTLM authentication requests from the compromised workstation, replaying the same hash against each target in rapid succession.

The timing was deliberate. All four authentication attempts were executed within an eight-minute window — fast enough to avoid manual detection, but spaced just enough to appear less like a scripted burst and more like organic activity.

Each successful authentication extended their reach deeper into the network. The attacker was mapping access — identifying where the credential worked, what permissions it carried, and which systems responded. This was reconnaissance disguised as legitimate authentication.

At this stage, the attacker had not yet escalated privileges or executed payloads on the target systems. This was a probing phase — testing the boundaries of access using stolen credentials. The real objective lay ahead: finding a path to higher privilege accounts or sensitive systems.

What the attacker did not account for was visibility at the identity layer. While the actions appeared valid from an authentication standpoint, the pattern — a single workstation authenticating via NTLM to multiple servers using the same hash — was not normal behavior for any legitimate user.

The movement had begun. And in doing so, it left a trail.

Section 4 — Detection & Alert

At **11:26 IST**, Microsoft Sentinel generated a **Critical severity incident** based on telemetry ingested from Microsoft Defender for Identity. The analytics rule responsible was designed to detect abnormal NTLM authentication patterns indicative of Pass-the-Hash activity.

The rule logic focused on identifying a single source device authenticating to multiple distinct hosts using NTLM within a short time window — a pattern rarely observed in legitimate user behavior.

Analytics Rule Name: *Suspected Pass-the-Hash Activity — Multiple NTLM Authentications*

KQL Rule Logic:

```
IdentityLogonEvents
| where TimeGenerated > ago(10m)  // Focus on recent authentication activity
| where Protocol == "NTLM"  // NTLM is commonly used in Pass-the-Hash attacks
| summarize TargetHosts = dcount(DeviceName), HostList = make_set(DeviceName)
   by AccountName, DeviceName, bin(TimeGenerated, 5m)  // Group by source device and
account
| where TargetHosts >= 3  // Threshold: authentication to 3 or more hosts
```

What Triggered the Alert:

At **11:24 IST**, a workstation identified as **FS-MUM-WS-447** initiated NTLM authentication attempts to four internal servers:

- FS-FILE-02
- FS-APP-01
- FS-DB-03
- FS-REPORT-01

All authentications were performed using the same domain account: **finsecure\rahul.s**

The activity occurred within an **8-minute window**, with no prior history of this workstation initiating multi-host NTLM authentication at this scale. Defender for Identity correlated the reuse of the same authentication material (NTLM hash) across these connections.

How the Alert Appeared in Sentinel:

- **Title:** Suspected Pass-the-Hash Activity — Multiple NTLM Authentications
- **Severity:** Critical
- **Time Generated:** 11:26 IST
- **Entities:**
    - Account: finsecure\rahul.s
    - Source Device: FS-MUM-WS-447
    - Target Devices: FS-FILE-02, FS-APP-01, FS-DB-03, FS-REPORT-01
- **Status:** New
- **Owner:** Unassigned

On the SOC floor, the central display emitted a sharp alert tone — the distinct signal reserved for Critical incidents. The incident immediately appeared at the top of the Sentinel queue, displacing all ongoing investigations.

Section 5 — L1 Triage

At **11:26 IST**, Arjun Mehta was midway through reviewing a Medium-severity alert related to a scheduled task anomaly. His left monitor showed the Sentinel Incidents queue, neatly sorted by severity. The sudden **audio alert tone** cut through the usual hum of the SOC floor.

He didn't look at the screen immediately. "Critical…" he muttered under his breath — a reflex more than a thought. His eyes shifted to the top of the queue. A new incident had appeared, bold and red.

"Suspected Pass-the-Hash Activity — Multiple NTLM Authentications."

He clicked it.

The right-side incident panel expanded. Arjun leaned slightly forward, scanning the entity list first — a habit he had built over time.

"Account… rahul.s… device… FS-MUM-WS-447… four target servers…" he read quietly, almost whispering each element.

His mouse moved to **Tab 2 — Entity Behavior**. He selected the account **finsecure\rahul.s**.

The 24-hour activity timeline loaded. Arjun's eyes tracked the graph. Normal sign-ins. Internal logins. No anomalies — until the last 10 minutes. A sudden spike in authentication activity.

He frowned.

"Rahul… operations team, right?" he said softly, flipping his notepad open and scribbling the username.

He switched to the **device entity — FS-MUM-WS-447**.

The pattern repeated. Minimal activity earlier in the morning. Then, within a tight window — multiple NTLM authentications to different servers.

Arjun paused. This was the moment.

He knew what Pass-the-Hash was — conceptually. He had seen it in training labs. But this was not a lab.

He hovered over the alert description again. *Same credential hash used across multiple hosts.*

He exhaled slowly.

"Okay… but did anything succeed?" he said, almost asking the screen.

He opened **Tab 3 — Defender for Identity** view embedded in Sentinel. The authentication entries showed **successful NTLM logons** to all four servers.

That tightened it.

He shifted to a quick validation step. In the Sentinel investigation panel, he checked timestamps:

- 11:17 — FS-FILE-02

- 11:19 — FS-APP-01
- 11:21 — FS-DB-03
- 11:24 — FS-REPORT-01

Sequential. Controlled.

Not a user clicking around.

Arjun leaned back slightly, tapping his pen against the notepad.

“Rahul wouldn’t hit four servers like this… not NTLM… and not in eight minutes,” he said.

Still, he hesitated — briefly.

Could this be some automated script? A maintenance job? He glanced at the **incident queue — no related maintenance alerts, no change windows logged**.

He shook his head.

“No. This is movement.”

Decision made.

He clicked into the **Incident Comments** section and began typing, carefully — no shorthand.

Then he opened **Microsoft Teams — SOC-Incidents channel** on his second monitor.

At **11:29 IST**, he posted the escalation and immediately tagged Rohan.

Escalation Message (SOC-Incidents Channel):

[INC-20260414-003 | Critical | Possible Pass-the-Hash]

Alert triggered for NTLM-based lateral authentication from workstation FS-MUM-WS-447 using account finsecure\rahul.s.

Observed 4 successful authentications to FS-FILE-02, FS-APP-01, FS-DB-03, FS-REPORT-01 within ~8 minutes (11:17–11:24 IST).

Entity behavior shows no prior pattern of multi-host NTLM activity for this user or device.

Initial assessment: Likely Pass-the-Hash lateral movement using compromised credentials.

Need L2 to validate credential source (possible LSASS dump), check prior activity on source host, and confirm any post-auth execution on target systems.

@Rohan — please review urgently.

He hit Enter.

Then he turned back to Sentinel — watching the incident, waiting for it to be picked up.

Section 6 — L2 Investigation

At **11:30 IST**, Rohan Desai's Microsoft Teams notification flashed on his right monitor. He didn't open Sentinel immediately. Instead, he clicked directly into the **SOC-Incidents channel** and read Arjun's escalation message line by line.

He nodded slightly.

"Good… clear… no assumptions," he said quietly.

Only then did he move to his center monitor and open **Microsoft Sentinel — Incident 48217**.

He expanded the **investigation graph** first.

A central node: **FS-MUM-WS-447**
Connected to: **rahul.s**
Branches extending to four servers.

Clean. Linear. Suspiciously efficient.

"This isn't noisy… this is controlled," he thought.

He opened **Notepad++** on monitor 2 — his KQL scratchpad already filled with previous investigations. He added a new section header:

// Incident: INC-20260414-003

// Objective: Validate Pass-the-Hash and identify source of credential compromise

Query 1 — Authentication Pattern Validation

// Question: Did the same account authenticate via NTLM to multiple hosts from a single device?

```
IdentityLogonEvents
| where TimeGenerated between (datetime(2026-04-14 11:10:00) .. datetime(2026-04-14 11:30:00))  // Investigation window
| where AccountName == "rahul.s"  // Target account
| where Protocol == "NTLM"  // Focus on NTLM authentication
```

```
| project TimeGenerated, DeviceName, DestinationDeviceName, ActionType, LogonType
| order by TimeGenerated asc
```

Result:

Four successful NTLM authentications originating from **FS-MUM-WS-447**, each targeting a different server.

Rohan traced the sequence with his finger on the screen.

“Sequential… not parallel… someone walking the network.”

No failed attempts. No noise.

That ruled out brute force. This was credential reuse.

He leaned back slightly.

“Where did the hash come from?”

Query 2 — Precursor Activity on Source Host

```
// Question: Was there credential dumping activity (LSASS access) on the source device prior to lateral movement?

DeviceProcessEvents
| where DeviceName == "FS-MUM-WS-447"  // Source workstation
| where TimeGenerated between (datetime(2026-04-14 09:00:00) .. datetime(2026-04-14 11:20:00))  // Look back 2 hours
| where ProcessCommandLine has_any ("lsass", "procdump", "comsvcs.dll", "sekurlsa")  // Indicators of credential dumping
| project TimeGenerated, FileName, ProcessCommandLine, InitiatingProcessFileName
| order by TimeGenerated asc
```

Result:

At **09:42 IST**, a process executed:

- **FileName:** rundll32.exe
- **CommandLine:** rundll32.exe C:\Windows\System32\comsvcs.dll, MiniDump 624 C:\Users\Public\lsass.dmp full

Rohan’s eyes narrowed.

“There it is.”

LSASS dump. Clean.

He followed up with a quick pivot — what initiated this process?

Another query revealed:

- **Initiating Process:** powershell.exe
- Encoded command executed minutes before.

He didn't need to decode it yet. The chain was clear.

"Initial access → PowerShell → LSASS dump → hash reuse."

He began constructing the timeline.

Attack Timeline

Timestamp (IST)	Event	Data Source	MITRE Technique
09:40	PowerShell execution (encoded command)	DeviceProcessEvents	T1059.001 — PowerShell
09:42	LSASS memory dump via comsvcs.dll	DeviceProcessEvents	T1003.001 — OS Credential Dumping
11:17	NTLM authentication to FS-FILE-02	IdentityLogonEvents	T1550.002 — Pass the Hash
11:19	NTLM authentication to FS-APP-01	IdentityLogonEvents	T1550.002
11:21	NTLM authentication to FS-DB-03	IdentityLogonEvents	T1550.002
11:24	NTLM authentication to FS-REPORT-01	IdentityLogonEvents	T1550.002

IOC Table

IOC	Type	Source	Enrichment Result
FS-MUM-WS-447	Host	IdentityLogonEvents	Internal workstation — no prior alerts
rahul.s	User	IdentityLogonEvents	Standard user — operations team
FS-FILE-02	Server	IdentityLogonEvents	Internal file server
FS-APP-01	Server	IdentityLogonEvents	Internal application server
FS-DB-03	Server	IdentityLogonEvents	Database server
FS-REPORT-01	Server	IdentityLogonEvents	Reporting server

rundll32.exe + comsvcs.dll	Process	DeviceProcessEvents	Known LSASS dump technique (malicious usage)

MITRE ATT&CK Mapping

- **T1059.001 — PowerShell Execution**
- **T1003.001 — OS Credential Dumping (LSASS)**
- **T1550.002 — Pass-the-Hash (Lateral Movement)**

Rohan leaned back, staring at the full picture.

“This isn’t just lateral movement… this is staged.”

He turned to containment.

Containment Recommendations

1. **Immediately isolate endpoint FS-MUM-WS-447** using Defender for Endpoint “Isolate Device” action
2. **Force password reset for account rahul.s** and revoke all active sessions via Azure AD
3. **Invalidate Kerberos tickets and NTLM sessions** for the account across all domain controllers
4. **Block NTLM authentication temporarily** for affected servers via Group Policy (restrict NTLM: deny all except approved list)
5. **Initiate memory scan on all four target servers** to verify no follow-on payload execution
6. **Review PowerShell execution logs enterprise-wide** for similar encoded command patterns
7. **Enable Defender for Identity alert tuning for NTLM anomalies** across non-admin accounts

He documented everything in Sentinel.

At **11:52 IST**, he updated the incident status.

“Confirmed compromise,” he said quietly.

Then he added one final note:

“L3 review required — detection triggered post-movement, not at credential dump stage.”

Section 7 — L3 Detection Tuning

At **13:10 IST**, Nisha Kapoor pulled up the incident report on her ultra-wide monitor. The SOC floor had settled into a quieter rhythm, but her focus was entirely on the document Rohan had just finalized. She didn’t skim. She read line by line — the LSASS dump at 09:42, the lateral movement at 11:17, the detection firing only at 11:26.

She leaned back slightly.

“Too late,” she said under her breath.

Her mouse moved to **Microsoft Sentinel → Analytics Rules**. She searched for the rule: **“Suspected Pass-the-Hash Activity — Multiple NTLM Authentications.”**

She opened it.

The KQL logic filled the screen — simple, clean, threshold-based. She read it once. Then again, slower.

Before-State KQL Rule

```
IdentityLogonEvents
| where TimeGenerated > ago(10m)
| where Protocol == "NTLM"
| summarize TargetHosts = dcount(DeviceName), HostList = make_set(DeviceName)
   by AccountName, DeviceName, bin(TimeGenerated, 5m)
| where TargetHosts >= 3
```

Nisha tapped her pen lightly against the desk.

“The rule works… but it waits for movement,” she thought.

She scrolled back to Rohan’s timeline. The LSASS dump happened **over an hour earlier**. That was the real inflection point — the moment the attacker gained reusable credentials.

She opened Notepad++ and began drafting.

Identified Weakness (Single Sentence)

The current rule detects lateral movement only after multiple NTLM authentications occur, missing the earlier and more critical signal of credential dumping activity on the source host.

She began writing the improved rule — not replacing the original entirely, but enhancing detection coverage by correlating **credential dumping indicators with NTLM authentication patterns**.

After-State Improved KQL Rule

```
// Step 1: Identify potential credential dumping activity (LSASS access)

let CredentialDumpingEvents = DeviceProcessEvents
| where TimeGenerated > ago(30m)
| where ProcessCommandLine has_any ("lsass", "comsvcs.dll", "MiniDump", "sekurlsa")  //
Known LSASS dump indicators
| project DumpTime = TimeGenerated, DeviceName, InitiatingProcessFileName;


// Step 2: Identify NTLM authentication activity from same device

let NTLMAuthEvents = IdentityLogonEvents
| where TimeGenerated > ago(30m)
| where Protocol == "NTLM"
| summarize TargetHosts = dcount(DestinationDeviceName), HostList =
make_set(DestinationDeviceName)
   by AccountName, DeviceName, bin(TimeGenerated, 5m)
| where TargetHosts >= 2;  // Lower threshold for earlier detection


// Step 3: Correlate both signals

CredentialDumpingEvents
| join kind=inner (NTLMAuthEvents) on DeviceName
| where NTLMAuthEvents_TimeGenerated > DumpTime  // Ensure lateral movement follows
dumping
| project DumpTime, NTLMAuthEvents_TimeGenerated, DeviceName, AccountName,
TargetHosts, HostList
```

She paused, reviewing the logic.

“Now we see the story, not just the ending,” she said.

This version did three things differently:

- It **looked for LSASS access first**, treating credential dumping as the primary signal

- It **reduced the NTLM threshold from 3 to 2 hosts**, allowing earlier detection of movement
- Most importantly, it **correlated both events**, ensuring that NTLM activity following credential dumping triggered an alert even before large-scale lateral spread

She added comments to the rule — concise, precise. Anyone reading it later would understand exactly why each condition existed.

Nisha saved the draft, then opened the rule editor again.

“This would have caught it at 09:45… not 11:26,” she said quietly.

And that difference — nearly two hours — was everything.

Section 8 — Final Incident Report

Part A — Executive Summary

On 14 April 2026, FinSecure Bank experienced a security incident involving unauthorized access to an internal workstation and subsequent movement across multiple internal servers. The attacker obtained user credentials from the compromised system and used them to access additional systems within the network.

The activity was detected and contained before any critical systems were modified or data was exfiltrated. The affected systems were isolated, and the compromised account was secured immediately.

No evidence of data loss or financial impact has been identified. Preventive improvements to detection capabilities have been implemented to ensure earlier identification of similar activity in the future.

Part B — Full Technical Summary

Incident ID: INC-20260414-003
Client: FinSecure Bank
Incident Type: Lateral Movement via Pass-the-Hash

Attack Type

Credential compromise followed by lateral movement using Pass-the-Hash technique.

MITRE ATT&CK Techniques

- **T1059.001 — PowerShell Execution**
- **T1003.001 — OS Credential Dumping (LSASS)**
- **T1550.002 — Pass-the-Hash (Lateral Movement)**

Timeline Summary

Timestamp (IST)	Event
09:40	PowerShell execution with encoded command
09:42	LSASS memory dump via comsvcs.dll
11:17–11:24	NTLM authentication to 4 internal servers
11:26	Sentinel alert triggered
11:29	Escalation to L2
11:52	Incident confirmed and containment initiated

Impact Assessment

- **Compromised Asset:** One workstation (FS-MUM-WS-447)
- **Compromised Account:** finsecure\rahul.s (standard user)
- **Affected Systems:** 4 internal servers (authentication access only)
- **Data Exfiltration:** Not observed
- **Privilege Escalation:** Not observed
- **Business Impact:** None confirmed

Full IOC List

IOC	Type	Source	Enrichment
FS-MUM-WS-447	Host	IdentityLogonEvents	Internal endpoint
rahul.s	User	IdentityLogonEvents	Standard user
FS-FILE-02	Server	IdentityLogonEvents	Internal asset
FS-APP-01	Server	IdentityLogonEvents	Internal asset
FS-DB-03	Server	IdentityLogonEvents	Internal asset
FS-REPORT-01	Server	IdentityLogonEvents	Internal asset

rundll32.exe + comsvcs.dll	Process	DeviceProcessEvents	LSASS dump technique

---

Containment Actions Taken

- Endpoint **FS-MUM-WS-447 isolated** via Defender for Endpoint
- Account **rahul.s password reset** and sessions revoked
- NTLM sessions invalidated across domain
- Target servers scanned for follow-on activity
- Monitoring increased for PowerShell-based execution patterns

---

Lessons Learned

- Credential dumping occurred significantly earlier than detection
- Existing detection logic focused on lateral movement, not credential access phase
- NTLM-based authentication remains a high-risk vector in hybrid environments
- Early-stage detection (credential dumping) is critical to reducing dwell time

---

Action Items

Action	Owner	Priority	Target Date
Implement correlated detection rule for LSASS access + NTLM activity	Nisha Kapoor (L3)	Critical	16-Apr-2026
Disable NTLM authentication where not required via Group Policy	Infrastructure Team	High	25-Apr-2026
Conduct enterprise-wide credential hygiene audit (password resets for high-risk users)	IAM Team	High	20-Apr-2026
Enable enhanced PowerShell logging (Script Block + Module Logging) across all endpoints	Security Engineering	High	18-Apr-2026
Review segmentation between user workstations and internal servers	Network Security Team	Medium	30-Apr-2026
Conduct user awareness training on initial compromise vectors	Security Awareness Team	Medium	05-May-2026